SIZMA TESTİ RAPORU

Rapor Tarihi	-
Hazırlayan	Ömer Faruk Baysal
Test Türü	PortSwigger Web Academy Lab

1. CSRF: Referer-tabanlı savunmanın atlatılması

Bu raporda, PortSwigger Web Security Academy'de yer alan ve Referer başlığına dayalı CSRF savunmasının atlatılmasına ilişkin bir lab ele alınmıştır.

2. Yönetici Özeti

Yapılan güvenlik testinde, hedef uygulamanın e-posta adresi değiştirme işlevinde Siteler Arası İstek Sahteciliği (CSRF) zafiyeti tespit edilmiştir. Uygulama bu işlemi, isteğin Referer başlığını doğrulayarak korumaya çalışmaktadır; ancak bu doğrulama yalnızca Referer başlığı istekte mevcut olduğunda gerçekleştirilmektedir. İstek herhangi bir Referer başlığı içermediğinde doğrulama tamamen atlanmakta ve işlem kabul edilmektedir. Bu mantık hatası nedeniyle bir saldırgan, isteğin Referer başlığını hiç göndermemesini sağlayarak doğrulamayı atlatabilmektedir.

Zafiyet, hazırlanan bir kavram kanıtı (PoC) ile doğrulanmış; oturumu açık bir kullanıcının, hazırlanan kötü niyetli bir sayfayı ziyaret etmesiyle e-posta adresinin saldırganın belirlediği bir adresle değiştirilebildiği gösterilmiştir. E-posta adresinin ele geçirilmesi, parola sıfırlama süreci aracılığıyla hesabın tümüyle ele geçirilmesine (account takeover) kadar ilerleyebileceğinden zafiyetin ivedilikle giderilmesi önerilmektedir.

3. Zafiyet Açıklaması

Hedef uygulamanın e-posta değiştirme işlevi (/my-account/change-email), durum değiştiren bu işlemi Siteler Arası İstek Sahteciliği'ne karşı korumak amacıyla isteğin Referer başlığını doğrulamaktadır. Yapılan incelemede, Referer başlığı uygulamanın kendi kaynağı dışında bir değer taşıdığında isteğin reddedildiği görülmüştür; bu, uygulamanın isteğin kaynağını Referer üzerinden denetlediğini göstermektedir.

Ancak bu doğrulama yalnızca Referer başlığının istekte bulunması durumunda çalışmaktadır. İstek herhangi bir Referer başlığı içermediğinde, sunucu doğrulama adımını tamamen atlamakta ve isteği koşulsuz olarak kabul etmektedir. Bu durum, doğrulama mantığının "Referer varsa doğrula" biçiminde kurgulanmasından, "Referer yoksa isteği reddet" koşulunun ise eksik bırakılmasından kaynaklanmaktadır. Sonuç olarak geçersiz bir Referer reddedilirken, Referer'ın hiç gönderilmemesi doğrulamayı devre dışı bırakmaktadır.

Tarayıcıların, bir sayfadan çıkan isteklere Referer başlığı ekleyip eklemeyeceği Referrer-Policy mekanizmasıyla denetlenebildiğinden, saldırgan hazırladığı sayfaya no-referrer politikası tanımlayarak, kurbanın tarayıcısının hedef isteğe Referer başlığı eklemesini engelleyebilmektedir. İşlevde ayrıca bir CSRF belirteci bulunmadığından, Referer başlığı

düşürüldüğünde işlem klasik bir form gönderimiyle gerçekleştirilebilmektedir. Bu da işlevi, Referer tabanlı savunmanın varlığına rağmen CSRF saldırısına açık hale getirmektedir.

4. Risk Seviyesi

Risk Seviyesi	Yüksek
CVSS v3.1 Skoru	8.1
CWE	CWE-352

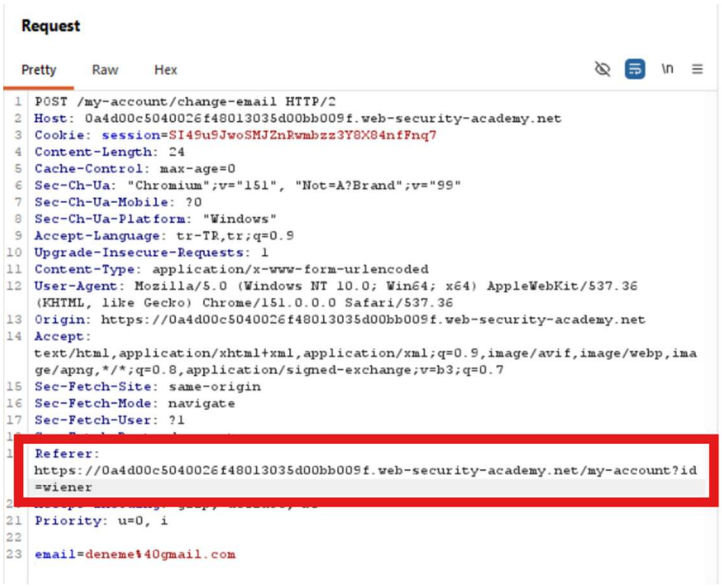
5. Etki

Zafiyetin başarıyla istismar edilmesi durumunda saldırgan, oturumu açık bir kurbanın hesabına tanımlı e-posta adresini, kurbanın bilgisi ve onayı olmaksızın değiştirebilmektedir. Saldırı, kurbanın yalnızca saldırgan kontrolündeki bir sayfayı ziyaret etmesiyle, herhangi bir ek etkileşim gerektirmeden gerçekleşmektedir.

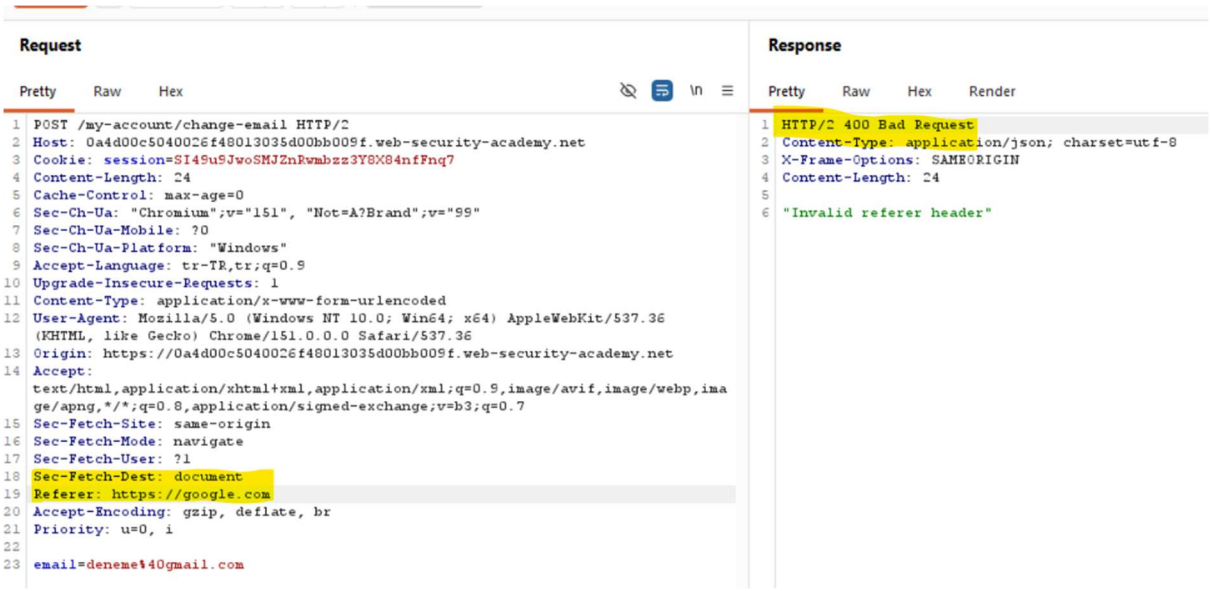
E-posta adresinin saldırgan tarafından belirlenen bir adresle değiştirilmesi, tek başına bir bütünlük ihlali oluşturmasının yanı sıra, uygulamanın parola sıfırlama sürecinin bu adres üzerinden işlemesi halinde hesabın tümüyle ele geçirilmesine (account takeover) olanak tanır. Bu durumda saldırgan, kurbanın hesabındaki kişisel verilere erişebilir ve hesap üzerinde kurban adına işlem yapabilir. Kimliğe bürünme yoluyla gerçekleştirilebilecek işlemler, uygulamanın niteliğine bağlı olarak itibar ve uyumluluk açısından da doğrudan etki yaratır.

6. Proof Of Concept

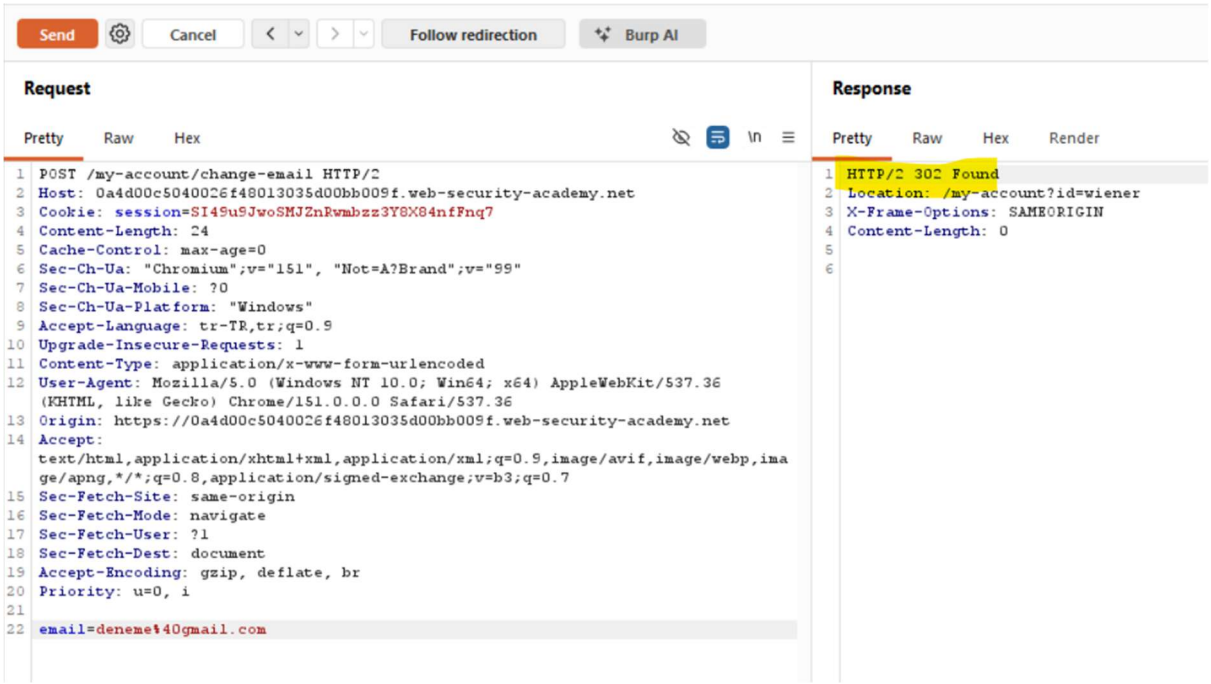
Uygulamaya wiener hesabıyla giriş yapılıp e-posta değiştirme işlevi kullanıldığında, işleme ait istek Burp Suite ile yakalanmıştır. İstekte, tarayıcı tarafından eklenen ve uygulamanın kendi kaynağını gösteren bir Referer başlığı bulunduğu görülmüştür.



Referer başlığının doğrulanıp doğrulanmadığını sınamak için istek Burp Repeater'a aktarılmıştır. Referer başlığı uygulama dışından bir değere (https://google.com) değiştirildiğinde, sunucu 400 Bad Request – "Invalid referer header" yanıtı döndürmüştür. Bu, uygulamanın isteğin kaynağını Referer üzerinden doğruladığını göstermektedir.



Ardından, doğrulamanın Referer başlığının yokluğunda da uygulanıp uygulanmadığını sınamak için istekten Referer başlığı tamamen kaldırılmıştır. Bu durumda sunucu isteği 302 Found yanıtıyla kabul etmiş ve e-posta adresini değiştirmiştir. Bu sonuç, doğrulamanın yalnızca Referer başlığı mevcut olduğunda çalıştığını; başlığın hiç bulunmaması durumunda ise tamamen atlandığını kanıtlamaktadır.

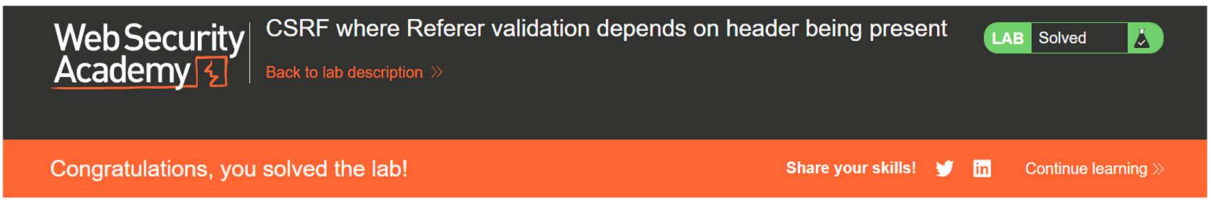


Bu bulgu aşağıdaki kavram kanıtında (PoC) kullanılmıştır. Saldırı sayfasının <head> bölümüne <meta name="referrer" content="no-referrer"> etiketi yerleştirilerek, kurbanın tarayıcısının bu sayfadan çıkan isteğe Referer başlığı eklememesi sağlanmıştır. Sayfa yüklendiğinde e-posta değiştirme formu otomatik olarak gönderilmekte; istek Referer başlığı taşımadığından doğrulama atlanmakta ve işlem gerçekleştirilmektedir.

Body:

```
<html>
  <head>
    <meta name="referrer" content="no-referrer">
  </head>
  <body>
    <form action="https://0a4d00c5040026f48013035d00bb009f.web-security-academy.net/my-account/change-email" method="POST">
      <input type="hidden" name="email" value="baysal@attacker.com" />
    </form>
    <script>
      document.forms[0].submit();
    </script>
  </body>
```

Kavram kanıtı exploit sunucusunda barındırılıp kurbana teslim edildiğinde, kurbanın e-posta adresi saldırganın belirlediği değerle değiştirilmiştir.



7. Çözüm Önerisi

Referer doğrulaması, başlığın varlığına koşullu olmamalıdır. Doğrulama yalnızca Referer mevcut olduğunda değil, başlığın bulunmadığı durumlarda da devreye girmeli ve geçerli bir Referer içermeyen istek varsayılan olarak reddedilmelidir (fail-closed). Güvenlik kararı "Referer varsa doğrula" değil, "geçerli Referer yoksa reddet" ilkesine dayanmalıdır.

Referer tabanlı doğrulama tek başına yeterli bir CSRF savunması olarak kullanılmamalıdır. Referer başlığı, Referrer-Policy gibi mekanizmalarla düşürülebildiğinden güvenilir bir kaynak doğrulaması sağlamaz. Bu nedenle durum değiştiren işlemler, oturuma bağlı, tahmin edilemez bir CSRF belirteci (token) ile korunmalıdır. Belirteç mevcut olsaydı, Referer düşürülse dahi saldırı belirteç eksikliği nedeniyle başarısız olurdu.

İsteğin kaynağı doğrulanırken Origin başlığı da kontrol edilmelidir. Durum değiştiren işlemlerde Origin başlığı denetlenerek, isteğin yalnızca uygulamanın kendi kaynağından kabul edilmesi sağlanmalıdır.

Tek bir kontrole güvenilmemelidir. Yukarıdaki önlemler savunma derinliği ilkesiyle birlikte uygulanmalı; herhangi bir kontrolün atlatılması durumunda diğerlerinin koruma sağlaması hedeflenmelidir.

Düzeltme sonrası yeniden test (retest) yapılmalıdır. Uygulanan önlemlerin zafiyeti gerçekten giderdiğini doğrulamak için, düzeltmenin ardından aynı işlev yeniden test edilmelidir.

8. Sonuç

Yapılan test sonucunda, hedef uygulamanın e-posta değiştirme işlevinin Siteler Arası İstek Sahteciliği (CSRF) zafiyetine açık olduğu tespit ve kavram kanıtı ile doğrulanmıştır. Uygulama,

isteğin Referer başlığını doğrulayarak bir savunma uygulamakla birlikte, bu doğrulamanın yalnızca Referer başlığı mevcut olduğunda yapılması ve başlık hiç gönderilmediğinde atlanması nedeniyle savunma atlatılabilmektedir. Saldırı, saldırı sayfasına no-referrer politikası tanımlanarak isteğin Referer başlığı taşımaması sağlanmak suretiyle gerçekleştirilmiştir. Zafiyet, hesabın tümüyle ele geçirilmesine kadar ilerleyebilecek etkisi nedeniyle yüksek risk seviyesinde değerlendirilmiş olup, önerilen önlemlerin uygulanarak ivedilikle giderilmesi tavsiye edilmektedir.
